Chapter 16
IT Controls Part II: Security and Access



Accounting Information Systems, 7e
James A. Hall

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Objectives for Chapter 16

- Be able to identify the principal threats to the operating system and the control techniques used to minimize the possibility of actual exposures.
- Be familiar with the principal risks associated with electronic commerce conducted over intranets and the Internet and understand the control techniques used to reduce these risks.
- Be familiar with the risks to database integrity and the controls used to mitigate them.
- Recognize the unique exposures that arise in connection with electronic data interchange (EDI) and understand how these exposures can be reduced.

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Operating Systems

- Perform three main tasks:
  - translates high-level languages into the machine-level language
  - allocates computer resources to user applications
  - manages the tasks of job scheduling and multiprogramming

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Requirements for Effective Operating Systems Performance

- Protect against tampering by users
- Prevent users from tampering with the programs of other users
- Safeguard users' applications from accidental corruption
- Safeguard its own programs from accidental corruption
- Protect itself from power failures and other disasters

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Operating Systems Security

- **Log-On Procedure**
  - first line of defense – user IDs and passwords
- **Access Token**
  - contains key information about the user
- **Access Control List**
  - defines access privileges of users
- **Discretionary Access Control**
  - allows user to grant access to another user

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Operating Systems Controls

Access Privileges

- *Audit objectives*: verify that access privileges are consistent with separation of incompatible functions and organization policies
- *Audit procedures*: review or verify…
  - policies for separating incompatible functions
  - a sample of user privileges, especially access to data and programs
  - security clearance checks of privileged employees
  - formal acknowledgements to maintain confidentiality of data
  - users' log-on times

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Operating Systems S Controls

Password Control

- *Audit objectives*: ensure adequacy and effectiveness of password policies for controlling access to the operating system
- *Audit procedures*: review or verify…
  - passwords required for all users
  - password instructions for new users
  - passwords changed regularly
  - password file for weak passwords
  - encryption of password file
  - password standards
  - account lockout policies

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Operating Systems Controls

Malicious & Destructive Programs

- *Audit objectives*: verify effectiveness of procedures to protect against programs such as viruses, worms, back doors, logic bombs, and Trojan horses
- *Audit procedures*: review or verify…
  - training of operations personnel concerning destructive programs
  - testing of new software prior to being implemented
  - currency of antiviral software and frequency of upgrades

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Operating System Controls

Audit Trail Controls

- *Audit objectives*: used to (1) detect unauthorized access, (2) facilitate event reconstruction, and/or (3) promote accountability
- *Audit procedures*: review or verify…
  - how long audit trails have been in place
  - archived log files for key indicators
  - monitoring and reporting of security violations

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Database Management Controls

Two crucial database control issues:

Access controls

- *Audit objectives*: (1) those authorized to use databases are limited to data needed to perform their duties and (2) unauthorized individuals are denied access to data

Backup controls

- *Audit objectives*: backup controls can adequately recover lost, destroyed, or corrupted data

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Access Controls

- **User views** - based on sub-schemas
- **Database authorization table** - allows greater authority to be specified
- **User-defined procedures** - used to create a personal security program or routine
- **Data encryption** - encoding algorithms
- **Biometric devices** - fingerprints, retina prints, or signature characteristics

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Database Authorization Table

Dept	Accounts Rec			Billings	
User	Jones	Smith	Adams	Check	Buell
Password	Bugs	Dog	Katie	Lucky	Star
Authority:					
Read	Y	Y	Y	Y	Y
Insert	Y	N	Y	Y	N
Modify	Y	N	N	Y	N
Delete	Y	N	N	N	N

Figure 16-2

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Access Controls

Audit procedures: verify…

- responsibility for authority tables & subschemas
- granting appropriate access authority
- use or feasibility of biometric controls
- use of encryption

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Subschema Restricting Access

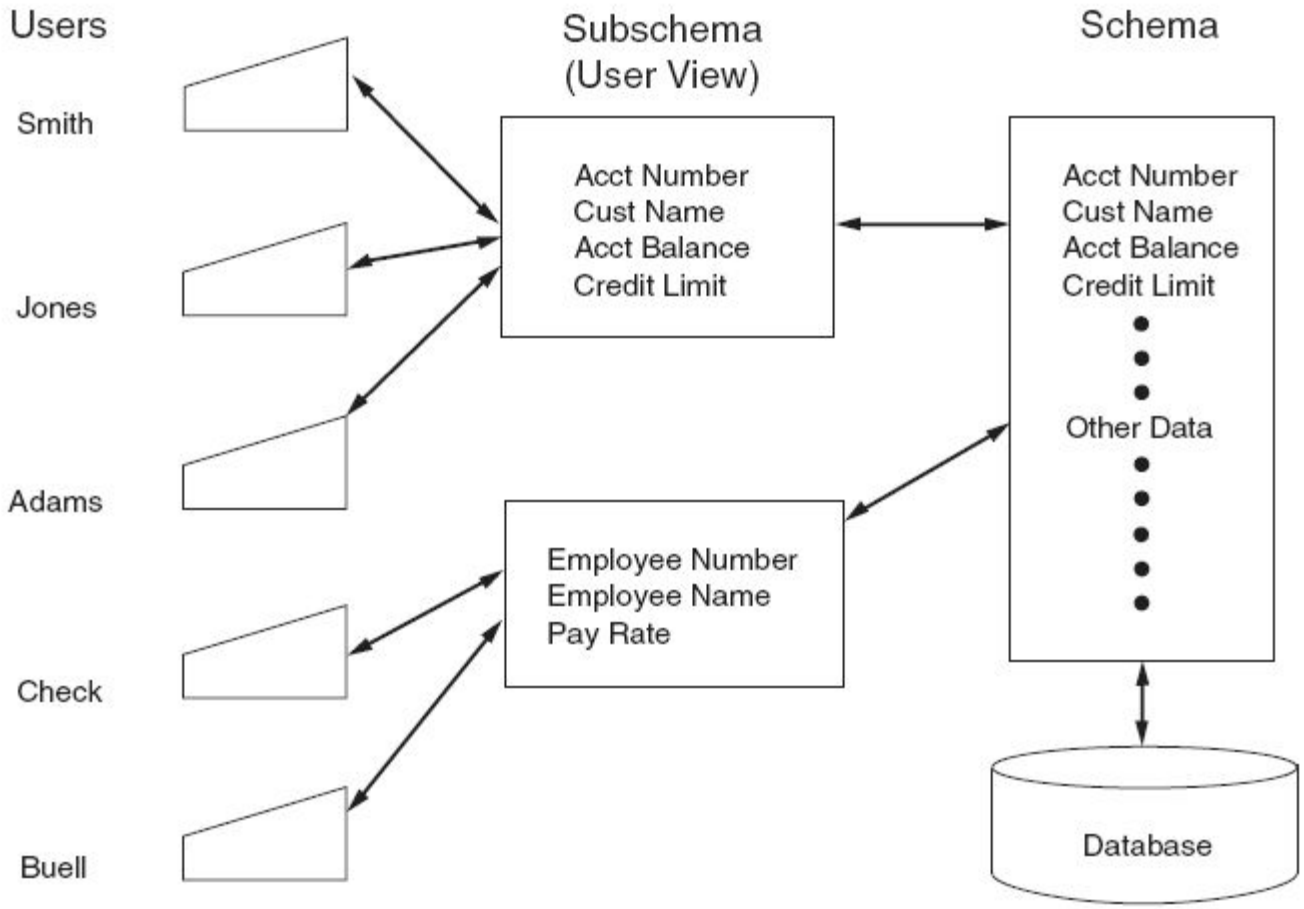


Figure 16-1

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Backup Controls

- **Database backup** – automatic periodic copy of data
- **Transaction log** – list of transactions that provides an audit trail
- **Checkpoint features** – suspends data during system reconciliation
- **Recovery module** – restarts the system after a failure

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Backup Controls

- *Audit procedures*: verify…
  - that production databases are copied at regular intervals
  - backup copies of the database are stored off site to support disaster recovery

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Internet and Intranet Risks

- The communications component is a unique aspect of computer networks:
  - different than processing (applications) or data storage (databases)
- Network topologies – configurations of:
  - communications lines (twisted-pair wires, coaxial cable, microwaves, fiber optics)
  - hardware components (modems, multiplexers, servers, front-end processors)
  - software (protocols, network control systems)

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Sources of Internet & Intranet Risks

Internal and external subversive activities

Audit objectives:

1. prevent and detect illegal internal and Internet network access
2. render useless any data captured by a perpetrator
3. preserve the integrity and physical security of data connected to the network

Equipment failure

Audit objective: the integrity of the electronic commerce transactions by determining that controls are in place to detect and correct message loss due to equipment failure

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Risks from Subversive Threats

- Include:
  - unauthorized interception of a message
  - gaining unauthorized access to an organization's network
  - a denial-of-service attack from a remote location

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

IC for Subversive Threats

Firewalls provide security by channeling all network connections through a control gateway.

- Network level firewalls
  - Low cost and low security access control
  - Do not explicitly authenticate outside users
  - Filter junk or improperly routed messages
  - Experienced hackers can easily penetrate the system
- Application level firewalls
  - Customizable network security, but expensive
  - Sophisticated functions such as logging or user authentication

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Dual-Homed Firewall

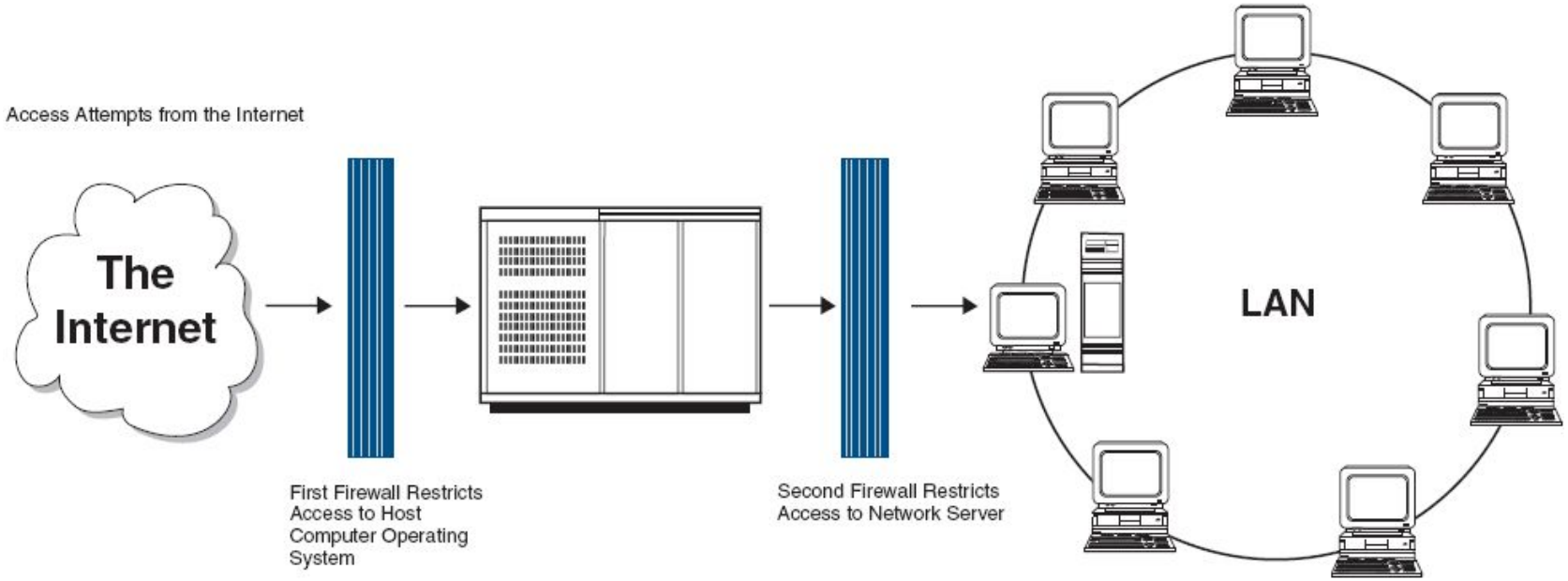


Figure 16-4

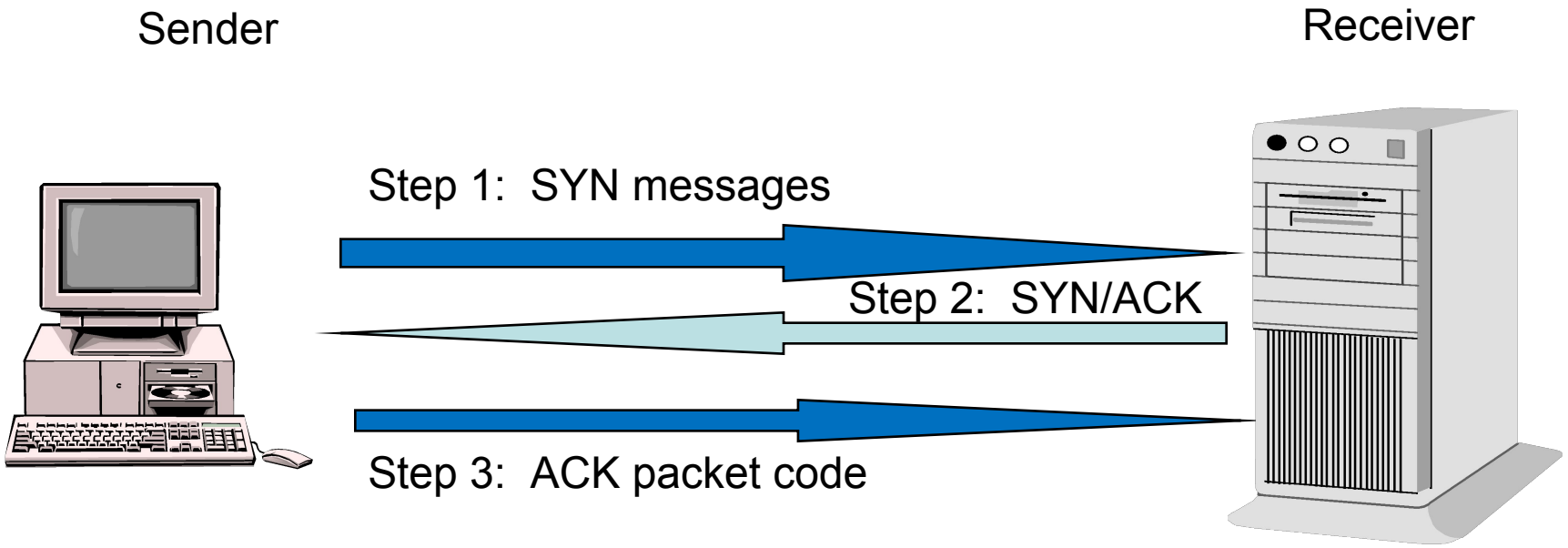
©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

IC for Subversive Threats

- **Denial-of-service (DOS) attacks**
  - Security software searches for connections which have been half-open for a period of time.
- **Encryption**
  - Computer program transforms a clear message into a coded (cipher) text form using an algorithm.

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

SYN Flood DOS Attack



In a DOS Attack, the sender sends hundreds of messages, receives the SYN/ACK packet, but does not response with an ACK packet. This leaves the receiver with clogged transmission ports, and legitimate messages cannot be received.

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Controlling DOS Attacks

- Controlling for three common forms of DOS attacks:
  - **Smurf attacks**—organizations can program firewalls to ignore an attacking site, once identified
  - **SYN flood attacks**—two tactics to defeat this DOS attack
    - Get Internet hosts to use firewalls that block invalid IP addresses
    - Use security software that scan for half-open connections
  - **DDos attacks**–many organizations use Intrusion Prevention Systems (IPS) that employ deep packet inspection (DPI)
    - IPS works with a firewall filter that removes malicious packets from the flow before they can affect servers and networks
    - DPI searches for protocol non-compliance and employs predefined criteria to decide if a packet can proceed to its destination

(*See chapter 12 for more on DOS attacks*)

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Encryption

- The conversion of data into a secret code for storage and transmission
- The sender uses an encryption algorithm to convert the original *cleartext* message into a coded *ciphertext*.
- The receiver decodes / decrypts the ciphertext back into cleartext.
- Encryption algorithms use **keys**
  - Typically 56 to 128 bits in length
  - The more bits in the key the stronger the encryption method.
- Two general approaches to encryption are *private key* and *public key* encryption.

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Private Key Encryption

- Advance encryption standard (AES)
  - A 128 bit encryption technique
  - A US government standard for private key encryption
  - Uses a single key known to both sender and receiver
- Triple Data Encryption Standard (DES)
  - Considerable improvement over single encryption techniques
  - Two forms of triple-DES encryption are EEE3 and EDE3
  - EEE3 uses three different keys to encrypt the message three times.
  - EDE3—one key encrypts, but two keys are required for decoding
- All private key techniques have a common problem
  - The more individuals who need to know the key, the greater the probability of it falling into the wrong hands.
  - The solution to this problem is public key encryption.

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

The Advanced Encryption Standard Technique

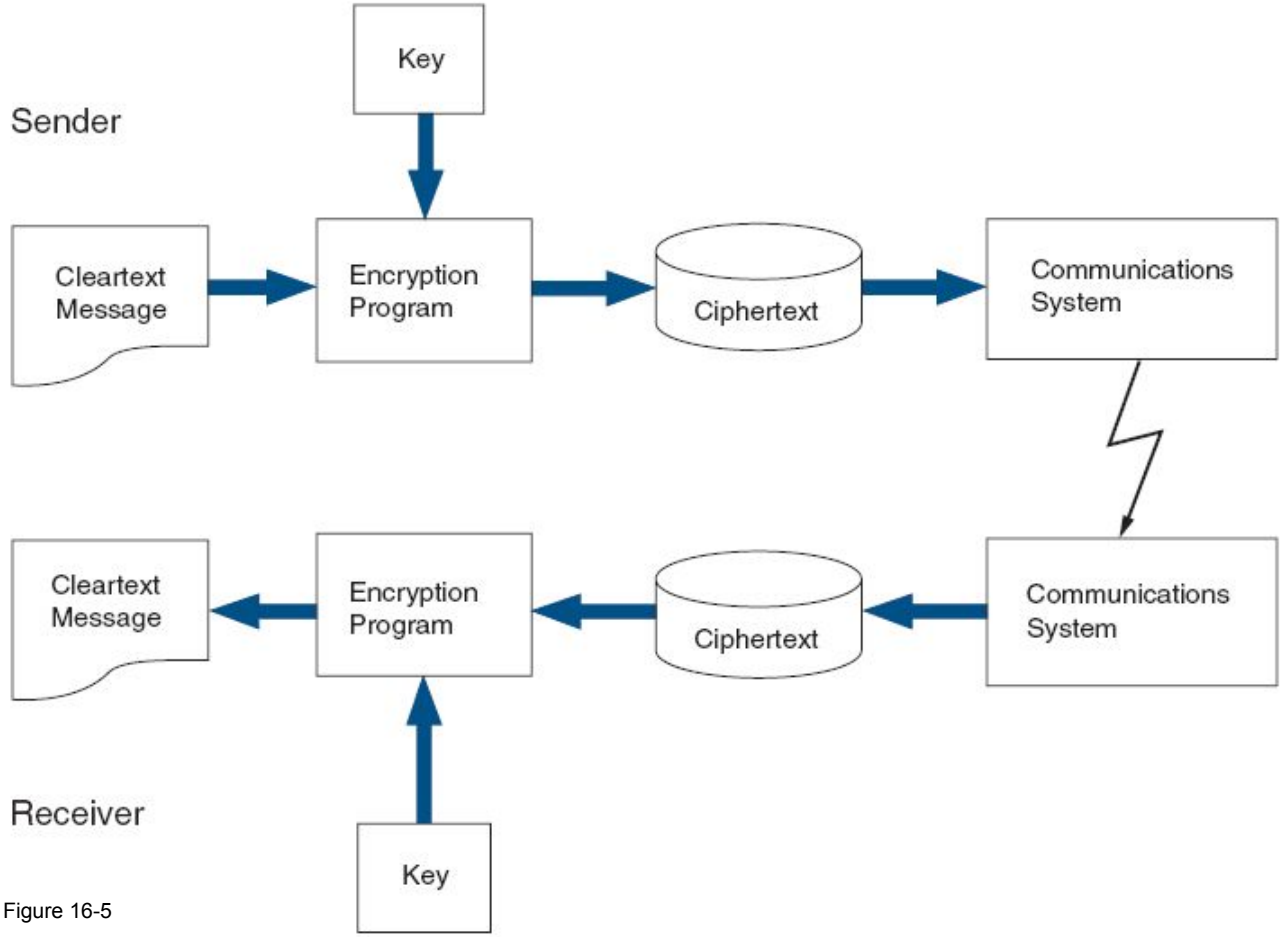


Figure 16-5

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

EEE3 and EDE3 Encryption

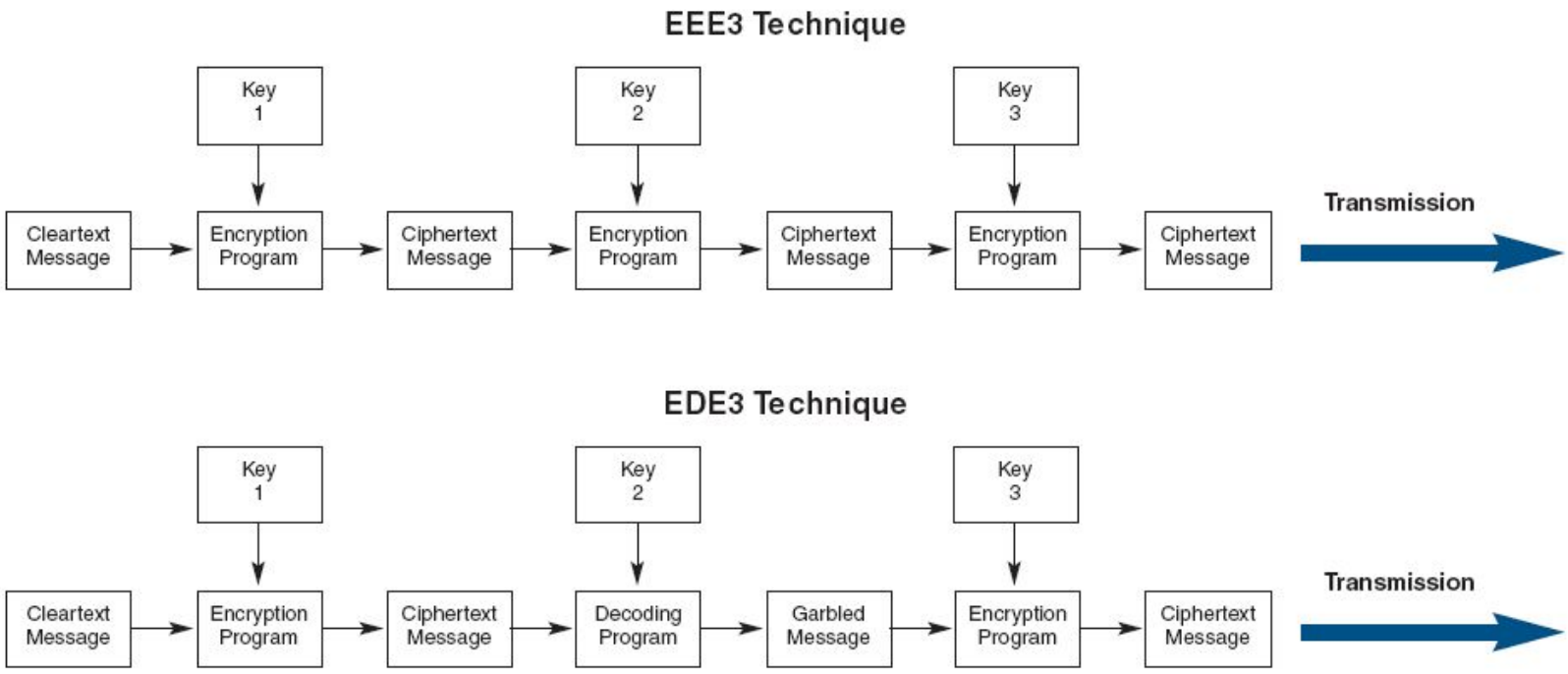


Figure 16-6

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

IC for Subversive Threats

- **Digital signature –** electronic authentication technique to ensure that…
  - transmitted message originated with the authorized sender
  - message was not tampered with after the signature was applied
- **Digital certificate –** like an electronic identification card used with a public key encryption system
  - Verifies the authenticity of the message sender

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Digital Signature

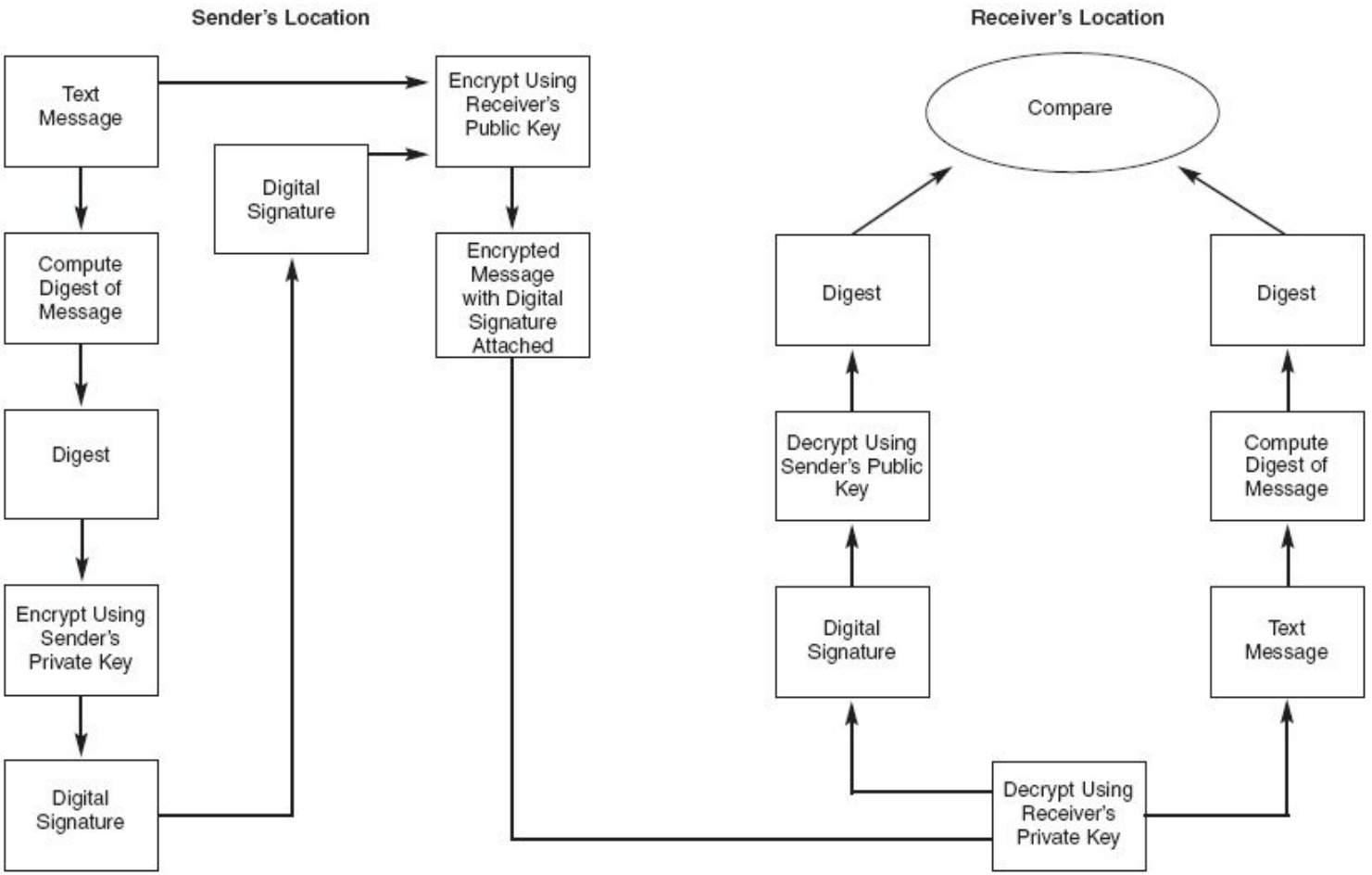


Figure 16-7

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

IC for Subversive Threats

- **Message sequence numbering –** sequence number used to detect missing messages
- **Message transaction log –** listing of all incoming and outgoing messages to detect the efforts of hackers
- **Request-response technique –** random control messages are sent from the sender to ensure messages are received
- **Call-back devices –** receiver calls the sender back at a pre-authorized phone number before transmission is completed

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Auditing Procedures for Subversive Threats

- Review firewall effectiveness in terms of flexibility, proxy services, filtering, segregation of systems, audit tools, and probing for weaknesses.
- Review data encryption security procedures
- Verify encryption by testing
- Review message transaction logs
- Test procedures for preventing unauthorized calls

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

IC for Equipment Failure

Line errors are data errors from communications noise.

- Two techniques to detect and correct such data errors are:
  - echo check - the receiver returns the message to the sender
  - parity checks - an extra bit is added onto each byte of data similar to check digits

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Vertical and Horizontal Parity using Odd Parity

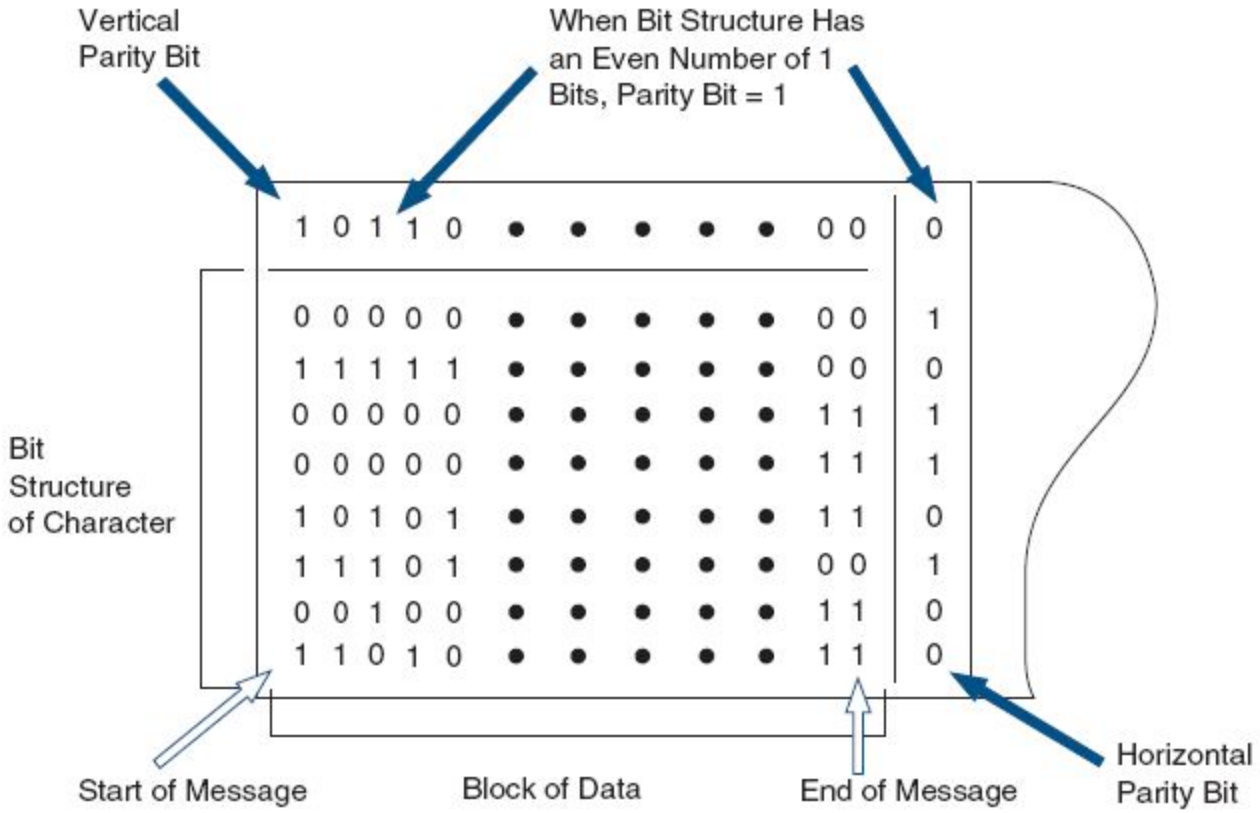


Figure 16-8

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Auditing Procedures for Equipment Failure

- Using a sample of messages from the transaction log:
  - examine them for garbled contents caused by line noise
  - verify that all corrupted messages were successfully retransmitted

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Electronic Data Interchange

- Electronic data interchange (EDI) uses computer-to-computer communications technologies to automate B2B purchases.
- Audit objectives:
  1. Transactions are authorized, validated, and in compliance with the trading partner agreement.
  2. No unauthorized organizations can gain access to database
  3. Authorized trading partners have access only to approved data.
  4. Adequate controls are in place to ensure a complete audit trail.

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

EDI Risks

- **Authorization**
  - automated and absence of human intervention
- **Access**
  - need to access EDI partner's files
- **Audit trail**
  - paperless and transparent (automatic) transactions

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

EDI Controls

- **Authorization**
  - use of passwords and value added networks (VAN) to ensure valid partner
- **Access**
  - software to specify what can be accessed and at what level
- **Audit trail**
  - control log records the transaction's flow through each phase of the transaction processing

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

EDI System

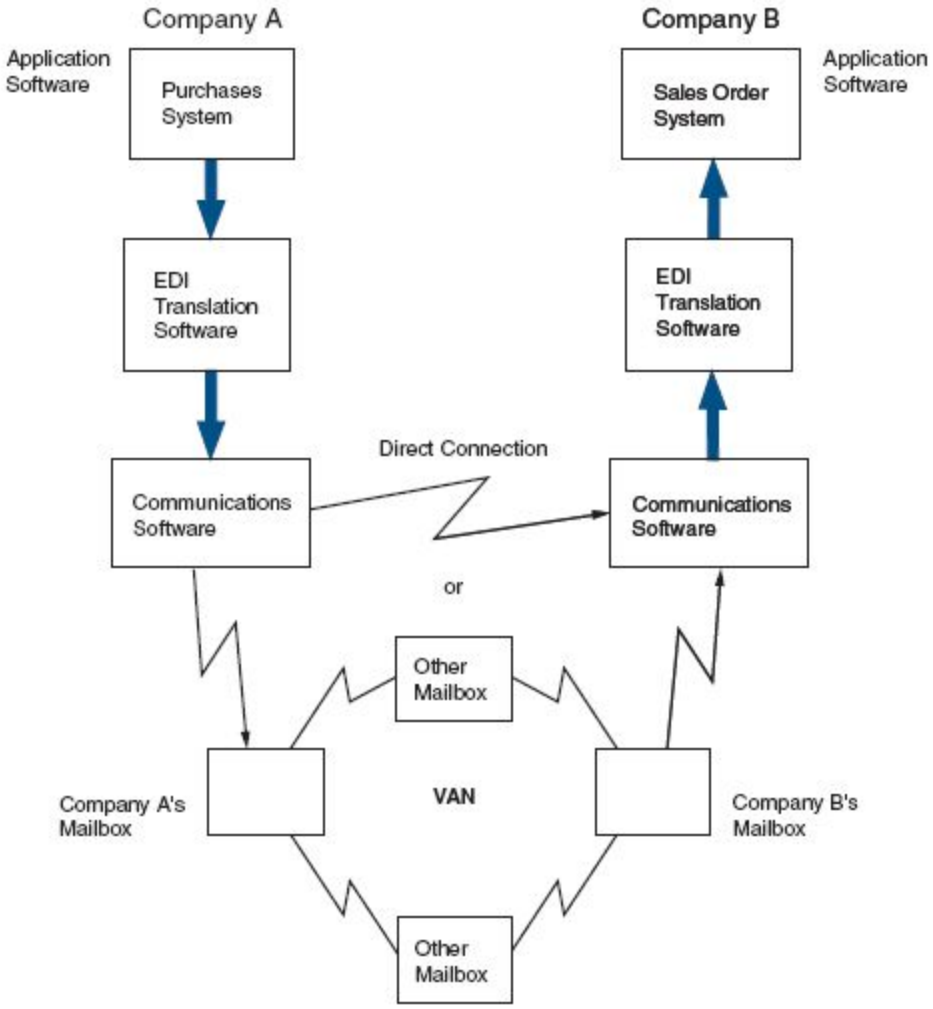


Figure 16-9

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

EDI System using Transaction Control Log for Audit Trail

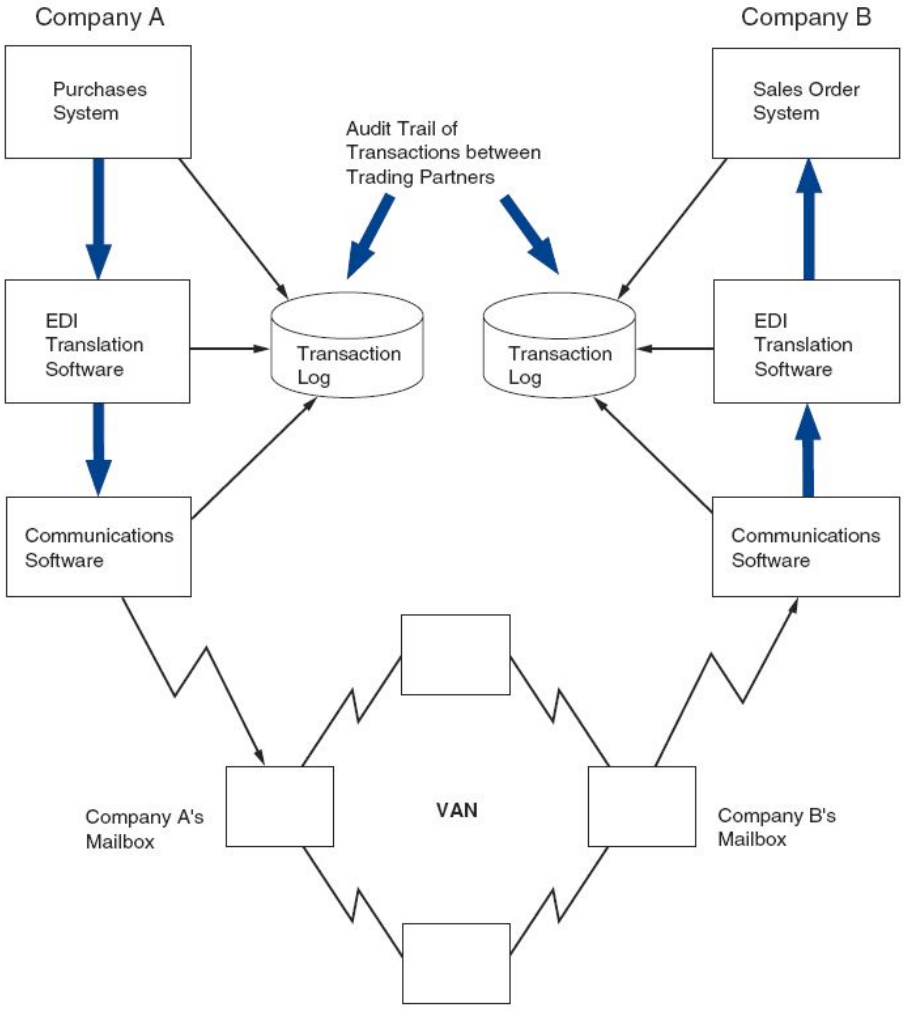


Figure 16-10

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Auditing Procedures for EDI

- ***Tests of Authorization and Validation Controls***
  - Review procedures for verifying trading partner identification codes
  - Review agreements with VAN
  - Review trading partner files
- ***Tests of Access Controls***
  - Verify limited access to vendor and customer files
  - Verify limited access of vendors to database
  - Test EDI controls by simulation
- ***Tests of Audit Trail Controls***
  - Verify existence of transaction logs
  - Review a sample of transactions

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.